



# ISO/IEC 27001

Control A.10.1: Procedimientos y responsabilidades de operación



Gestión de comunicaciones y operaciones

# 1. Alcance del Control

Este control abarca la definición y el mantenimiento de las responsabilidades y procedimientos operativos necesarios para asegurar el manejo correcto y seguro de las instalaciones de procesamiento de información.

- ✓ **Cobertura:** Sistemas de TI, redes, aplicaciones y servicios críticos.
- ✓ **Contexto:** Se aplica a todo el personal y terceros que operan infraestructuras de la organización.
- ✓ **Marco Legal:** Cumplimiento con políticas internas y regulaciones de protección de datos.



## 2. Objetivo

**"Garantizar la operación correcta y segura de las instalaciones de procesamiento de información"**

El propósito fundamental es minimizar el riesgo de fallas operativas, accesos no autorizados y errores humanos mediante la estandarización y control de las actividades diarias de TI.



**Integridad**



**Disponibilidad**



**Confidencialidad**

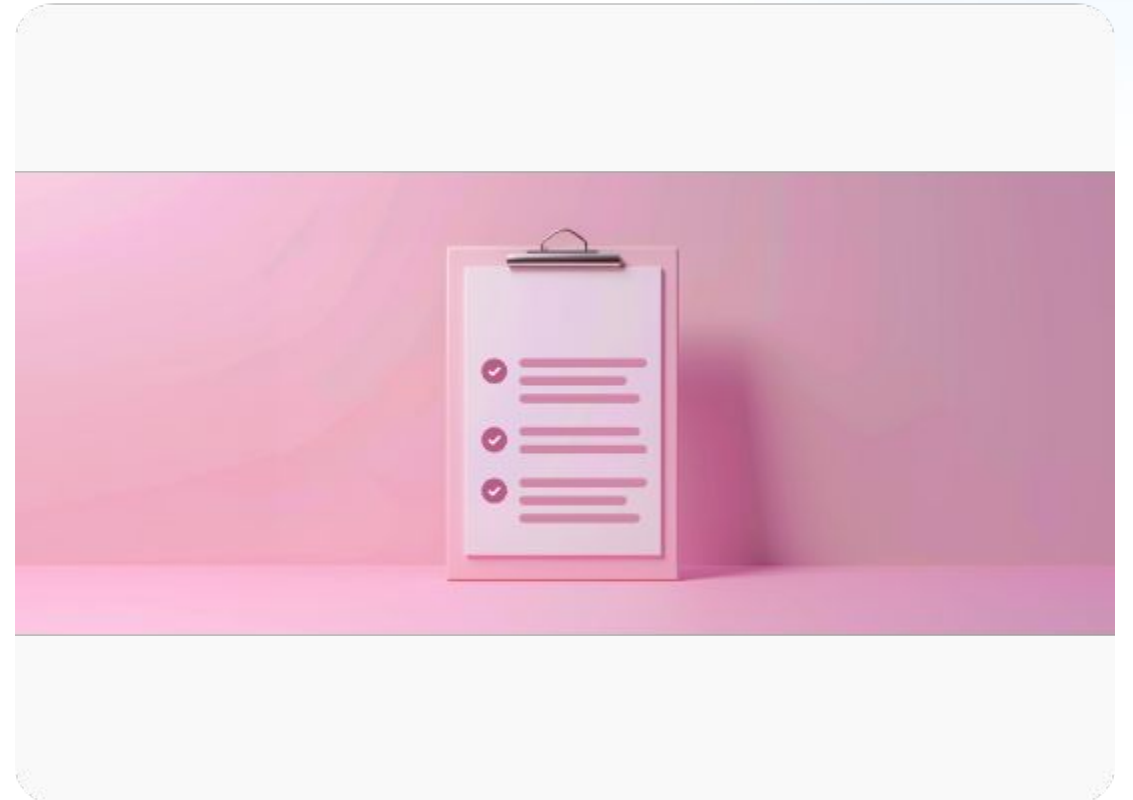
## A.10.1.1 Documentación

### Procedimientos operativos

**Explicación:** Los procedimientos deben estar escritos y disponibles para todos los usuarios que los necesiten. Incluyen tareas como copias de seguridad, programación de trabajos y manejo de errores.

**Ejemplo:** Manual de ejecución del proceso de respaldo nocturno en la nube, detallando pasos ante fallos de conexión.

**Importancia:** Evita la dependencia de "conocimiento tribal" (personas específicas) y garantiza que las tareas se ejecuten siempre igual.



# CHECKLIST DE AUDITORÍA

CONTROL: A.10.1.1

| Pregunta de Verificación                                                | Sí                       | No                       | N/A                      |
|-------------------------------------------------------------------------|--------------------------|--------------------------|--------------------------|
| ¿Existen manuales de operación documentados para los sistemas críticos? | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| ¿Están los procedimientos actualizados y aprobados por la dirección?    | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| ¿Tienen los operadores acceso fácil a la documentación en sus puestos?  | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |

## A.10.1.2 Gestión de Cambios

### Control de cambios en sistemas

**Explicación:** Todo cambio en la configuración de hardware, software o red debe ser controlado. Debe haber una solicitud, evaluación de impacto, aprobación e implementación.

**Ejemplo:** Antes de actualizar el sistema ERP, se realiza una prueba en un entorno espejo y se requiere firma del jefe de TI.

**Importancia:** Reduce drásticamente la probabilidad de que un cambio mal aplicado tumbe los servicios de la empresa.



## CHECKLIST DE AUDITORÍA

CONTROL: A.10.1.2

| Pregunta de Verificación                                                  | Sí                       | No                       | N/A                      |
|---------------------------------------------------------------------------|--------------------------|--------------------------|--------------------------|
| ¿Se registran formalmente todas las solicitudes de cambios en el sistema? | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| ¿Existe un análisis de riesgos previo a la ejecución de cambios mayores?  | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| ¿Se define un plan de "rollback" o retorno atrás en caso de fallo?        | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |

## A.10.1.3 Segregación

### Segregación de tareas

**Explicación:** Ninguna persona debe tener control total sobre un proceso crítico. Las tareas deben dividirse para prevenir fraudes o errores accidentales no detectados.

**Ejemplo:** La persona que desarrolla un software no debe ser la misma que aprueba su paso a producción final.

**Importancia:** Actúa como un control preventivo contra actividades malintencionadas internas y mejora la detección de errores.





CHECKLIST DE AUDITORÍA

CONTROL: A.10.1.3

| Pregunta de Verificación                                                             | Sí                       | No                       | N/A                      |
|--------------------------------------------------------------------------------------|--------------------------|--------------------------|--------------------------|
| ¿Están claramente definidas las responsabilidades para evitar conflictos de interés? | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| ¿Se requiere supervisión o aprobación dual para actividades críticas?                | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| ¿Existe registro de logs que permita auditar quién realizó cada acción?              | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |

## A.10.1.4 Ambientes

### Separación de ambientes

**Explicación:** Los entornos de Desarrollo, Pruebas y Operación (Producción) deben estar aislados para evitar cambios accidentales en los datos reales.

**Ejemplo:** Los programadores trabajan en un servidor local (Dev) y solo tras pruebas rigurosas el código se mueve al servidor de los clientes.

**Importancia:** Previene que errores en el código nuevo afecten la disponibilidad del servicio a los clientes finales.



## CHECKLIST DE AUDITORÍA

CONTROL: A.10.1.4

| Pregunta de Verificación                                                     | Sí                       | No                       | N/A                      |
|------------------------------------------------------------------------------|--------------------------|--------------------------|--------------------------|
| ¿Se utilizan redes o servidores distintos para desarrollo y producción?      | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| ¿Se prohíbe el uso de datos reales de clientes en el ambiente de desarrollo? | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |
| ¿Existen reglas de acceso diferentes para el personal en cada ambiente?      | <input type="checkbox"/> | <input type="checkbox"/> | <input type="checkbox"/> |



**¡Gracias por su atención!**

¿Tienen alguna pregunta sobre la implementación del control

A.10.1?

ISO/IEC 27001:2013 - Auditoría de Cumplimiento Operativo

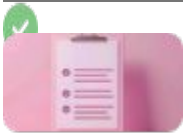
# Image Sources



<https://images.drata.com/x3hoqyj3c27/4qG0yKiTGxuDna10VVqJQ8/7742493a42a0070618a1b9d86be27499/Blog-Featured-Images-9.png>

Source: [drata.com](https://drata.com)

---



[https://cdn.shopify.com/s/files/1/0070/7032/articles/standard\\_20operating\\_20procedure\\_1848x970\\_cbb8e93e-520b-43b8-87db-e5f0740facd0.png?v=1729254379](https://cdn.shopify.com/s/files/1/0070/7032/articles/standard_20operating_20procedure_1848x970_cbb8e93e-520b-43b8-87db-e5f0740facd0.png?v=1729254379)

Source: [www.shopify.com](https://www.shopify.com)

---



<https://www.slidescarnival.com/wp-content/uploads/Minimal-Change-Management-Process-Flow-Diagrams-5.jpg>

Source: [www.slidescarnival.com](https://www.slidescarnival.com)

---



[https://cdn.prod.website-files.com/62189d34242d01cd9d5887ab/68e00150396be3e4cad4478a\\_Separation%20of%20Duties%20header.png](https://cdn.prod.website-files.com/62189d34242d01cd9d5887ab/68e00150396be3e4cad4478a_Separation%20of%20Duties%20header.png)

Source: [www.lumos.com](https://www.lumos.com)

---



[https://testomat.io/wp-content/uploads/2025/11/Screenshot\\_20251031\\_161855\\_Canva-530x325.jpg](https://testomat.io/wp-content/uploads/2025/11/Screenshot_20251031_161855_Canva-530x325.jpg)

Source: [testomat.io](https://testomat.io)